

turknet

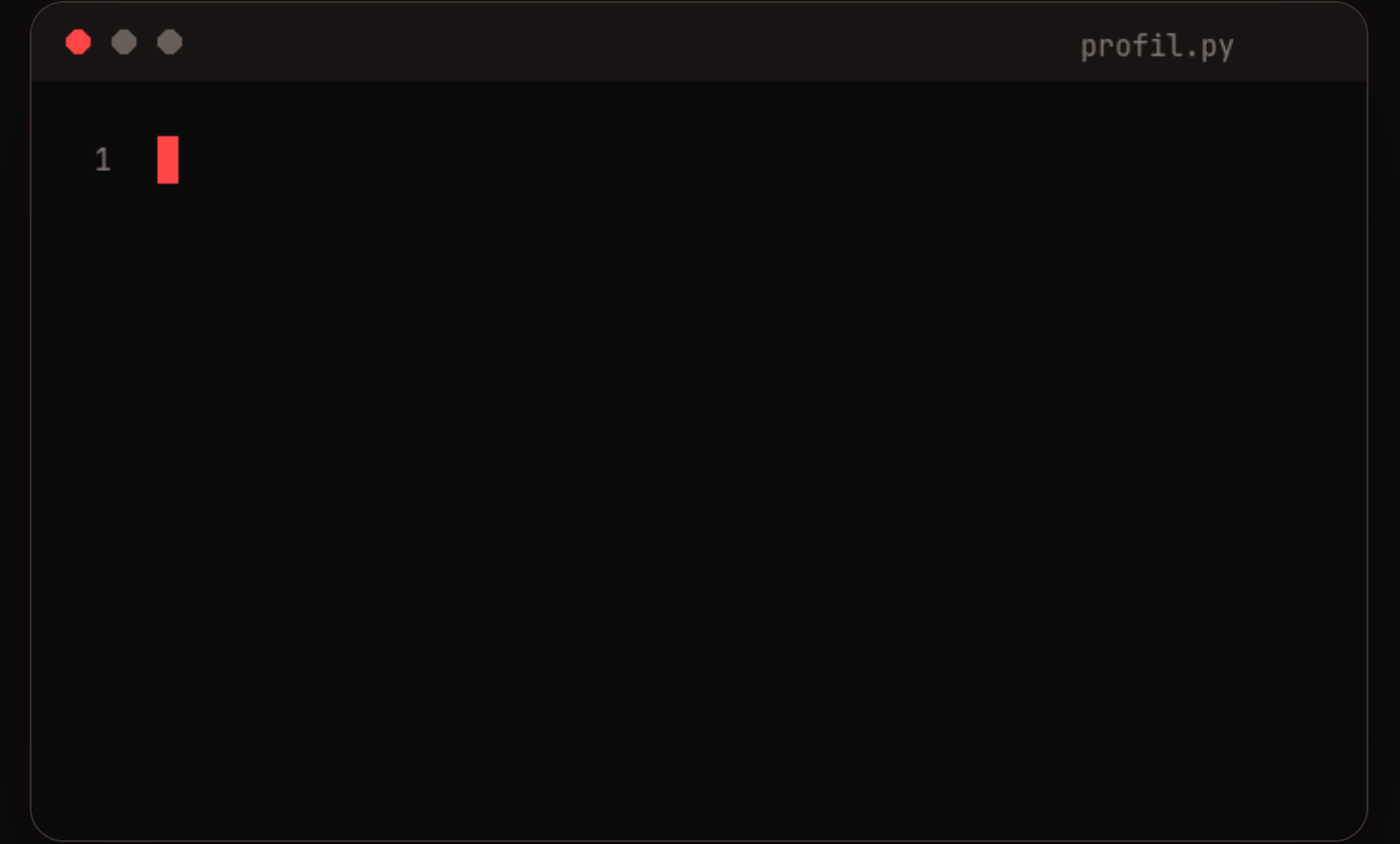
2026-27 GÜZ DÖNEMİ • HAFTA 2

Güven sınırını geçmek

Tehdit modelleme ve enjeksiyon: girdinin koda
dönüştüğü an

Can Öztaş

github.com/canoztas/secure-coding



BUGÜN

Bugünün akışı

- | | | |
|----|--------------------------------|--|
| 01 | Kısa tekrar | Geçen haftanın üç fikri: güvenilmeyen girdi, güven sınırı, saldırganın sorusu. |
| 02 | Tehdit modelleme | Bir sistemi saldırganın gözünden çizmek: DFD ve STRIDE. |
| 03 | Enjeksiyonun kök nedeni | Veri ile kodun aynı kanalda birleşmesi. |
| 04 | SQL, komut, yol | Aynı hatanın üç yüzü ve tek yapısal savunma. |

TEKRAR

Geçen haftadan üç fikir

01

Güvenilmeyen girdi

Güven sınırını geçen her şey girdidir ve kanıtlanana kadar güvenilmezdir.

02

Güven sınırı

Kararlar sunucuda alınır; istemcide yapılan doğrulama isteğe bağlıdır.

03

İki soru

“Ne yapmalı?” testlerin sorusu. “Başka ne yapabilir?” saldırganın sorusu.

Bu hafta üçünü tek bir zafiyet sınıfında —enjeksiyon— birlikte göreceğiz.

BÖLÜM A

Tehdit modelleme

Kod yazmadan önce: bu sistemi kim, nereden, nasıl kırabilir?



YÖNTEM

Dört soru

SORU 1

Ne inşa ediyoruz?

Sistemi veri akış diyagramıyla (DFD) çiz: süreçler, depolar, aktörler, güven sınırları.

SORU 2

Ne ters gidebilir?

Her sınırı geçen okta STRIDE'ı uygula: hangi tehdit sınıfı mümkün?

SORU 3

Ne yapacağız?

Her tehdide bir karşı önlem; kabul edilen riski açıkça yaz.

SORU 4

İyi iş çıkardık mı?

Modeli kod ve testlerle karşılaştır; sistem değişince modeli güncelle.

Adam Shostack'ın dört sorusu. Model bir kez değil, sistem değiştikçe yenilenir.

Altı tehdit sınıfı

Harf	Tehdit	Kırdığı ilke	Örnek
S	Spoofing (kimlik taklidi)	Kimlik doğrulama	Başkasının oturumuyla giriş
T	Tampering (kurcalama)	Bütünlük	Fiyatı ya da rolü değiştirmek
R	Repudiation (inkâr)	İzlenebilirlik	İşlemi yapmadım demek, log yok
I	Information disclosure	Gizlilik	Veri sızıntısı
D	Denial of service	Erişilebilirlik	Servisi durdurmak
E	Elevation of privilege	Yetkilendirme	Kullanıcıdan yöneticiye çıkmak

Geçen haftanın kodunu modelleyelim

```
# güven sınırı: tarayıcı →|→ sunucu
```

```
GET /profil?id=1
```

```
# süreç: profil()
```

```
# depo: kullanıcılar tablosu
```

```
# akış: id → SQL sorgusu → DB
```

Tampering + Information Disclosure

id alanı bir güven sınırını geçiyor ve doğrudan sorguya giriyor. STRIDE'in T ve I harfleri tam da burada. Kök neden hep aynı: veri, koda dönüşüyor.

Aynı diyagram komut satırında, dosya yollarında ve şablon motorlarında da tekrar eder.

BÖLÜM B

Enjeksiyon

OWASP Top 10 · A05:2025 — hâlâ en yaygın ve en ölümcül sınıflardan biri.



Tek bir kök neden: veri ile kod aynı kanalda.

Uygulama bir metin kuruyor; metnin bir kısmı sizin kodunuz, bir kısmı kullanıcının verisi. Yorumlayıcı ikisini ayırt edemez. Savunma kaçış karakteri eklemek değil, kanalları ayırmaktır.



Aynı hata, farklı yorumlayıcı

SQL

Veritabanı

Sorgu metnine giren girdi — CWE-89.

OS

Kabuk / komut

Komut satırına giren girdi — CWE-78.

PATH

Dosya sistemi

Yola giren girdi (../) — CWE-22.

TEMPLATE

Şablon motoru

İfade olarak yorumlanan girdi —
CWE-1336.

NoSQL

Belge sorgusu

Operatör enjekte eden girdi — CWE-943.

XML

Ayrıştırıcı

Harici varlık (XXE) — CWE-611.

SQL

Girdi sorguya dönüşünce

```
uid = request.args.get("id")          # güvenilmeyen
q = "SELECT ad FROM kullanicilar "
q += "WHERE id = " + uid               # veri, sorgu metnine yapıştı
db.execute(q)
```

Beklenen

id = 1 → tek kullanıcı döner.

Girdi değişince

id, sorgunun mantığını değiştirecek şekilde seçilirse tek satır yerine tablonun tamamı dönebilir.

Enjeksiyon nasıl görünür

Tür	Fikir	Belirti
In-band	Sonuç doğrudan yanıtta görünür (UNION, hata mesajı).	Sayfada fazladan veri
Blind (boolean)	Yanıt doğru/yanlışına göre değişir.	İçerik var/yok
Blind (zaman)	Koşullu gecikme ile bit bit okuma.	Yavaş yanıt
Second-order	Girdi saklanır, sonra başka sorguda tetiklenir.	Gecikmeli etki

BÖLÜM B1

Adım adım bir SQLi

Bir giriş formunu satır satır kıralım, sonra aynı formu düzeltelim.



Kırılğan giriş uç noktası

```
@app.route("/giris", methods=["POST"])
def giris():
    ad = request.form["ad"]          # güvenilmeyen
    pw = request.form["parola"]      # güvenilmeyen
    q = ("SELECT * FROM hesap WHERE "
         "ad = '" + ad + "' AND parola = '" + pw + "'")
    return "ok" if db.execute(q).fetchone() else "401"
```

İki alan da doğrudan sorgu metnine yapışıyor. Şimdi üç istekle ne olduğunu izleyelim.

Beklenen davranış

```
POST /giris      ad=ali      parola=1234
```

kurulan sorgu:

```
SELECT * FROM hesap WHERE ad = 'ali' AND parola = '1234'
```

Ne gitti

ad ve parola alanları beklenen biçimde.

Ne oldu

Eşleşen tek satır döner → giriş başarılı. Test bu senaryoyu görür ve geçer.

Parola hiç kontrol edilmedi

```
POST /giris      ad=' OR '1'='1' --      parola=x
```

```
# girdi tırnağı kapattı, -- kalanı yorum yaptı:
```

```
SELECT * FROM hesap WHERE ad = '' OR '1'='1' --' AND parola = 'x'
```

Ne yaptı

'1'='1' her zaman doğru; parola koşulu -- ile silindi.

Ne çıktı

İlk satır (çoğu kez yönetici) döner → parolasız giriş.

UNION ile başka tabloyu ekle

```
GET /profil?id=0 UNION SELECT ad, parola FROM hesap --
```

kurulan sorgu:

```
SELECT ad, eposta FROM uye WHERE id = 0  
UNION SELECT ad, parola FROM hesap --
```

Ne yaptı

id=0 hiç satır getirmez; UNION ikinci sorgunun sonucunu yanıtı ekler.

Ne çıktı

Tüm hesapların adı ve parola özeti sayfada listelenir.

Dil değişti, kök neden aynı

```
// Statement + string birleştirme = aynı açık
String q = "SELECT * FROM hesap WHERE ad = '" + ad + "'";
Statement st = conn.createStatement();
ResultSet rs = st.executeQuery(q);
//   ad = ' OR '1'='1   →   Adım 2'nin aynısı
```

SQLi bir dile ya da çerçeveye özgü değil; veriyle kodu aynı kanalda birleştiren her yerde çıkar.

Girdi artık veri, kod değil

```
# Python – parametrelili
q = "SELECT * FROM hesap WHERE ad = ? AND parola = ?"
db.execute(q, (ad, pw))

// Java – PreparedStatement
var ps = c.prepareStatement("... WHERE ad = ?");
ps.setString(1, ad);
```

Adım 2'yi tekrar dene

ad = " ' OR '1'='1' -- " artık bu metinde bir kullanıcı adı aranır.

Sonuç

Böyle bir ad yok → eşleşme yok → 401. Sınıfın tamamı kapandı.

Yanıt görünmese de sızar

```
-- 1) Boolean: yanıt doğru/yanlış'a göre değişir
id=1 AND (SELECT SUBSTR(parola,1,1) FROM hesap LIMIT 1)='a'
--   sayfa normal → harf doğru ; boş → yanlış

-- 2) Zaman tabanlı: koşul doğruysa yanıt gecikir
id=1 AND IF(SUBSTR(parola,1,1)='a', SLEEP(3), 0)
```

Yanıta hiç veri görünmese bile bilgi bit bit çıkarılabilir; “çıktı yok” güvenlik değildir.

ORM tek başına korumaz

```
# Django – ham SQL'de string birleştirme yine açık
Kullanici.objects.raw("... WHERE ad = '%s'" % ad)      # x
Kullanici.objects.raw("... WHERE ad = %s", [ad])        # ✓

# SQLAlchemy – text() içinde de aynı kural
session.execute(text("... WHERE ad = '" + ad + "'"))  # x
session.execute(text("... WHERE ad = :ad"), {"ad": ad}) # ✓
```

ORM'in normal sorgu kurucusu güvenlidir; tehlike `.raw()/.extra()/text()` ile metne döndüğünüz yeredir.

Savunma: hazır ifade (prepared statement).

Sorgunun iskeleti sabit derlenir; kullanıcı verisi ayrı bir kanaldan parametre olarak gider. Yorumlayıcı artık veriyi kod olarak okuyamaz — sınıfın tamamı kapanır.

SQL

Kanalları ayırmak

```
# x veri koda karışıyor
q = "... WHERE id = " + uid

# ✓ iskelet sabit, veri parametre
cur.execute(
    "... WHERE id = %s", (uid,))
```

Aynı ilke her dilde var: sorgu metnine değil, ayrı parametre kanalına yaz.

Her dilde aynı ilke

```
// Java – PreparedStatement
var ps = c.prepareStatement("... WHERE id = ?");
ps.setInt(1, id);

// C# – parametrelili komut
cmd.CommandText = "... WHERE id = @id";
cmd.Parameters.AddWithValue("@id", id);

// PHP (PDO) ve Node (pg)
$pdo->prepare("... WHERE id = ?")->execute([$id]);
$client->query("... WHERE id = $1", [id]);
```

Yer tutucu farklı (?, @id, \$1) ama fikir tek: veri asla sorgu metni olmaz.

Parametrelenemeyeni izin listesiyle bağla

```
# ✗ sıralama sütunu doğrudan girdiden
q = f"SELECT * FROM urun ORDER BY {kolon}"    # kolon = ?

# ✓ kolon/tablo adı parametre olamaz → izin listesi
IZIN = {"ad", "fiyat", "tarih"}
if kolon not in IZIN:
    raise ValueError('gecersiz kolon')
q = f"SELECT * FROM urun ORDER BY {kolon}"    # artık güvenli
```

Tablo adları, kolon adları, ORDER BY yönü parametrelenemez; hepsini sabit bir kümeye eşle.

KOMUT

Kabuğa giden girdi

```
# ✗ kabuk metni kuruluyor
os.system("ping -c1 " + host)          # host saldırganın

# ✓ argümanlar dizi olarak, kabuk yok
subprocess.run(["ping", "-c1", host], shell=False)
```

Kök neden

shell=True kabuğu araya sokar; kabuk metni ayrıştırır ve girdi komuta dönüşür.

Kalıcı risk

Kanal ayrılrsa bile argüman enjeksiyonu (-o, -- ile başlayan girdi) sürebilir; girdiyi yine doğrula.

KOMUT • ARGÜMAN

Kanal ayrıldı, risk bitmedi

```
# kabuk yok ama girdi hâlâ bir ARGÜMANA dönüşüyor
subprocess.run(["git", "log", kullanıcı_girdisi])
# girdi "--output=/etc/cron.d/x" olabilir → seçenek enjeksiyonu

# ✓ değerleri -- ile ayır ve biçimi doğruyla
subprocess.run(["git", "log", "--", dosya])
```

Argüman enjeksiyonu (CWE-88): girdi komut değil ama bir bayrak gibi yorumlanır. -- ayırıcı ve allowlist şart.

YOL

Dosya yoluna giden girdi

```
# ✗ kullanıcı adı yola yapışıyor
open("/veri/" + ad)                                # ad = "../../etc/..." olabilir

# ✓ önce kanonikleştir, sonra kök içinde mi diye doğrula
tam = os.path.realpath(os.path.join(KOK, ad))
assert tam.startswith(KOK + os.sep)
```

Kural: birleştir → kanonikleştir (realpath) → sınırı doğrula. Uzantı ve içerik kontrolü de eklenir.

Girdi tipi değişince koşul çöker

```
// beklenen: iki string ile eşleşme
db.hesap.find({ kullanıcı: girdiK, parola: girdiP })

// girdiP bir NESNE olursa: { "$ne": null }
//   → parola ≠ null her zaman doğru   → kimlik atlatma

// ✓ girdinin string olduğunu doğrula
if (typeof girdiP !== "string") return reddet();
```

NoSQL'de de kök neden aynı: veri (string) bir operatöre (kod) dönüşüyor. JSON gövdesinde tip doğrulaması şart.

SSTI

Girdi şablonun kendisi olmamalı

```
# x kullanıcı verisi ŞABLON metnine giriyor
render_template_string("Merhaba " + ad)

# ad = {{7*7}} → ekranda 49 → motor girdiyi çalıştırdı

# ✓ veri, şablona PARAMETRE olarak girer
render_template("selam.html", ad=ad) # {{ ad }} yalnızca metin
```

SSTI (CWE-1336)

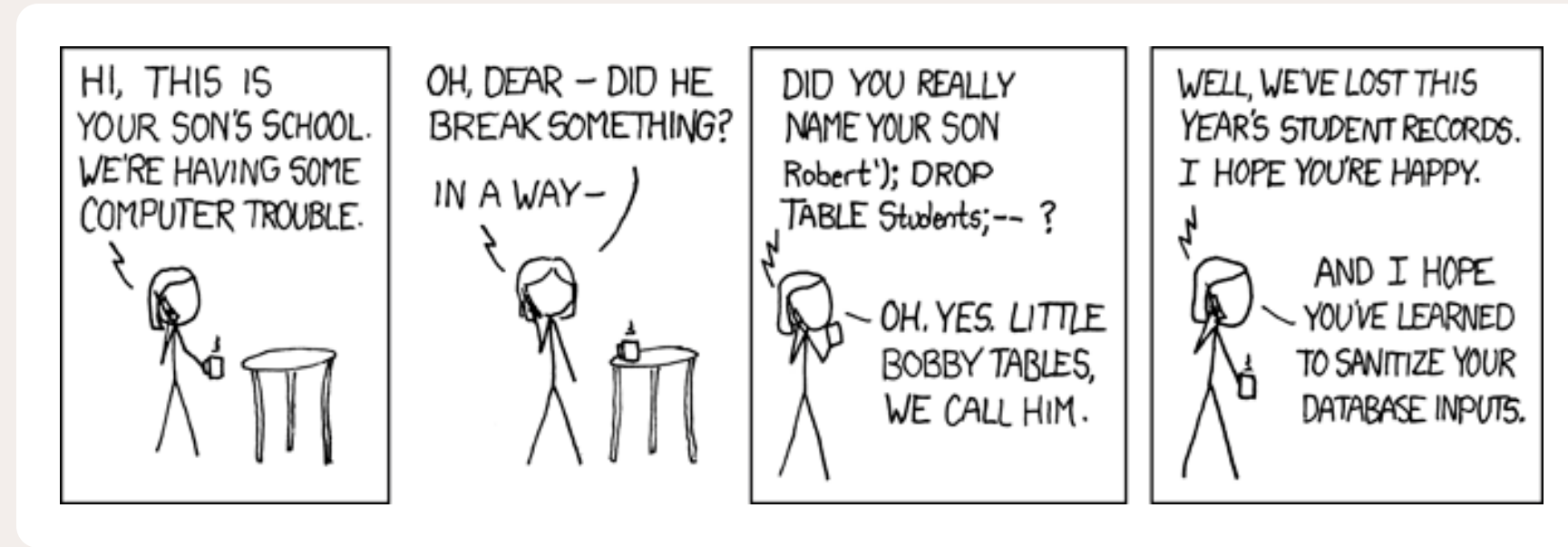
Girdi ifade olarak yorumlanırsa uzaktan kod çalıştırmaya kadar gider.

XXE (CWE-611)

XML'de de aynı sınıf: harici varlıkları ve DTD'yi kapat; ayrıştırıcı varsayılanı güvensiz.

KLASİK

xkcd 327 — “Little Bobby Tables”



Okul öğrencinin adını doğrudan sorguya koymuş. Espri gerçek: girdi her zaman veri kalmalı.

BÖLÜM C

Vaka otopsisı

MOVEit Transfer · CVE-2023-34362 — tek bir SQLi'nin nereye kadar gittiği.



MOVEit Transfer • CVE-2023-34362

Ürün

Kurumların dosya taşıdığı yönetilen transfer yazılımı (MOVEit Transfer).

Kök neden

web uygulamasının /human.aspx istek işleyicisi, kullanıcı girdisini SQL'e sanitize etmeden koyuyor — CWE-89.

Mayıs 2023, sıfıncı gün (zero-day). ClOp (TA505) kitlesel sömürdü; yüzlerce kurumdan veri sızdı.

Bir enjeksiyondan tam ele geçirmeye

- | | | |
|----|------------------------------|---|
| 01 | SQL enjeksiyonu | /human.aspx'e hazırlanmış istek → veritabanı şeması ve kimlik bilgileri okunur. |
| 02 | Ayrıcalık | DB'den yönetici (sysadmin) API erişim token'ı çekilir / sahte oturum kurulur. |
| 03 | Deserialization → RCE | Token'la API'deki güvensiz nesne çözme noktasına payload → kod çalıştırma. |
| 04 | Kalıcılık | human2.aspx (LEMURLOOT) web shell wwwroot'a bırakılır → toplu veri sızdırma. |

Zincirin ilk halkası tek bir SQLi. O halka kırılıyorsa geriye çökerdi.

Hangi desen açtı? (temsîlî)

```
// istek işleyicisinde string birleştirmeyele SQL
string q = "SELECT ... WHERE x = '" + Request["p"] + "'";
db.Exec(q);                                // x girdi = kod

// olması gereken: parametrelî komut
cmd.CommandText = "SELECT ... WHERE x = @p";
cmd.Parameters.AddWithValue("@p", Request["p"]);
```

Tek bir uç noktadaki birleştirme bütün zinciri açtı. “Çalışan kod, güvenli kod değildir.”

Otopsi raporunun dört başlığı

KOD

Kanalı ayır

Her uç noktada parametrelili sorgu / ORM binding. String birleştirme kalmasın.

YAMA

Sürümü yükselt

Progress yamaları: 2021.0.6 / 2021.1.4 / 2022.0.4 / 2022.1.5 / 2023.0.1.

AZALT

Saldırı yüzeyi

Dışa açık HTTP/S'i kıs, human2.aspx ve IOC'leri ara, DB'ye en az yetki.

ÇIKARIM

Ders

Tek zafiyet = tam ihlal. Girdi doğrulama + savunmayı katmanla.

Dönem projeniz (bireysel otopsi) tam bu dört başlığı içermeli: kök neden, zincir, yama, çıkarım.

ÖZET

Bir cümlede

KÖK NEDEN

Aynı kanal

Veri ile kod tek metinde birleşiyor.

SAVUNMA

Kanalı ayır

Parametre, argüman dizisi, kanonik yol, güvenli şablon.

TASARIM

En az yetki

Kırılsa bile hasar dar kalsın.

HAFTAYA

Haftaya kadar

PortSwigger

Web Security Academy’de SQL injection ve OS command injection laboratuvarlarından birer tanesini bitirin.

Kendi ortamınız

DVWA ya da Juice Shop’u Docker’da çalıştırın; istekleri Burp’ten izleyin.

Haftaya: tarayıcı güvenlik modeli, XSS ve CSRF. Etik: yalnızca kendi laboratuvarınızda.



SORU • CEVAP

Sorular?

